Segurança nas Pipelines — SAST, DAST, SCA, Secrets

Bernoulli · repositório `pipeline-templates` (Azure DevOps, org bernoullidevops / Produtos Digitais, branch `devops`) · 22/09/2026

As "6 famílias" = tipo de recurso Azure de destino (App Service, Function, Function via contêiner, Static Web, SWA, Container App) — não é Lovable vs. Azure "puro". Lovable é um modo dentro das famílias webapp e SWA (`isLovableProject`: muda nome do Environment e default de secrets), mesmo pipeline e mesmos controles de segurança descritos abaixo.

Categoria	Estado atual	Lacuna	Proposta	Prioridade
SAST (SonarQube)	Pausa intencional Segue desligado de propósito (decisão da equipe, não bug). Continua chamado em todas as famílias, atrás do parâmetro `enabled` (default `false`).	Nenhuma análise estática roda hoje — mas por decisão consciente, não por lacuna.	Sem ação necessária agora. Infra pronta (SonarQube self-hosted) pra quando a pausa for revista; Semgrep é opção leve a avaliar como complemento (sem servidor próprio).	Baixa
SCA (OWASP Dependency-Check)	Ativo e funcionando Roda como Job próprio (`SCA_DependencyCheck`), com agente e checkout próprios, em paralelo ao Build — chama diretamente o template de steps `setup/dependency-check.yml`, sem depender do SonarQube nem de nenhum outro Job. Presente nas 6 famílias de orquestrador (webapp, function, function-container, static-web, SWA, container apps).	Cobertura total — nenhuma lacuna nos orquestradores.	Sem ação necessária.	Baixa
Secrets (Gitleaks)	Ativo e funcionando Toggle `enableGitleaks` por repositório (modo `warn`, telemetria própria no App Insights interno). Presente nas 6 famílias de orquestrador (webapp, function, function-container, static-web, SWA, container apps).	Cobertura total nos orquestradores; roda em modo `warn`, não bloqueia merge hoje.	Avaliar promover de `warn` para bloqueante em produção.	Média
Imagens de contêiner	Nunca existiu Nenhuma menção a scanner de imagem nos templates, apesar de Container Apps / Function / WebApp em contêiner publicarem no ACR.	Cobertura total ausente.	Trivy como step no build (grátis, esforço baixo) ou Microsoft Defender for Containers (nativo — confirmar se Defender for Cloud já está habilitado antes de assumir custo novo).	Média
DAST	Nunca existiu Nenhuma menção em nenhum template.	Nenhuma aplicação é testada em runtime.	OWASP ZAP baseline scan (grátis) contra o ambiente alpha pós-deploy, começando informativo. Esforço médio-alto (alvo, autenticação, falso positivo).	Baixa/Média
RLS Supabase (Vibe Scanner)	Ativo e funcionando Job próprio (`SupabaseRLSAudit`) varre as migrations em busca de políticas RLS ausentes/fracas; gera SARIF (aba Scans) e relatório MD. Modo `warn` por padrão.	Só existe na família SWA — nenhuma outra família com Supabase tem o mesmo scan.	Sem ação necessária hoje. Estender pro mesmo padrão se outra família passar a usar Supabase.	Baixa

Outros controles de segurança já em prática: **Key Vault** — segredos (chaves de API, connection strings) sempre buscados em runtime via Managed Identity, nunca em texto plano nas pipelines (usado em ~30 templates); **Managed Identity + RBAC automatizado** — `acr-rbac-template.yml` e `validate-keyvault-template.yml` conferem/configuram identidade gerenciada e roles (AcrPull, acesso ao Key Vault) antes do deploy, eliminando credenciais estáticas de ACR e Function App; **Supabase Edge Functions** — verificação de JWT ligada por padrão (`verifyJwt`) nas famílias webapp e SWA, bloqueando chamada não autenticada; **APIM (Functions expostas via gateway)** — sync automático injeta a function key na policy (função `anonymous` não fica acessível direto) e remove operações órfãs do gateway a cada deploy (`pruneMissingOperations`).